

Wayne Corp Website Defacement Investigation Report

Incident Investigation Report

Wayne Corp Website Defacement — imreallynotbatman.com

Analyst: Dilin **Dataset:** Splunk BOTS v1 (Boss of the SOC)
Investigation platform: Splunk Enterprise (local instance) **Index:** botsv1 **Date of incident (per log data):** August 29, 2016 **Report status:** In progress — Scenario 1 (Website Defacement)

1. Executive Summary

Wayne Corp's public-facing website, `imreallynotbatman.com`, was defaced by a threat actor group referred to in the scenario narrative as **po1s0n1vy**. The attacker conducted automated vulnerability scanning against the site, identified it as running the Joomla content management system, and successfully uploaded a defacement image to the server. The attack infrastructure used a dynamic DNS domain to obscure and control the malicious hosting IP.

This report documents the investigative process, findings, and supporting evidence gathered using Splunk Search Processing Language (SPL) against the BOTS v1 dataset.

2. Environment Overview

Item	Value
Total events in dataset	~33,413,777
Time span of dataset	Aug 29, 2016, approx. 7-hour window
Unique hosts in environment	1,760
Key sourcetypes	WinEventLog:Security, XmlWinEventLog:...Sysmon, fgt_traffic/fgt_event/fgt_utm (Fortigate firewall), stream:http, stream:dns, stream:ldap, suricata, iis, nessus:scan
IDS sensor	suricata-ids.waynecorpinc.local
Target organization	Wayne Corp (waynecorpinc.local)

3. Timeline of Findings — Scenario 1 (Website Defacement)

Step	Finding	Value	Evid
1	Attacker scanning IP identified	40.80.148.42	stream:ht analysis (site)
2	Scanning tool identified	Acunetix Web Vulnerability Scanner (Free Edition)	HTTP hea Product in
3	Target CMS identified	Joomla	URI path (/joomla/
4	Defacement image identified	imnotbatman.jpg	uri/uri_p stream:ht
5	Victim server internal IP identified	192.168.250.70	stream:dn imreallyn
6	Malicious dynamic DNS domain identified	prankglassinebracket.jumpingcrab.com (serving on port 1337)	Host/site request fr coming-fo stream:ht
7	Brute-force target username identified	admin	Raw POS login requ
8	Total brute-force login attempts	413 (412 from a single source in one 10-min window)	Count of /administ containin stream:ht
8b	Correction: Brute-force source IP identified as distinct from the scanning IP	23.22.63.114 (not 40.80.148.42)	Detection see Secti
9	Brute-force succeeded — timestamp identified	2016-08-11 03:18:05.858 UTC	Anomalous (1061 byt ~854-857 failures),
9b	Correction: Successful login source IP identified as 40.80.148.42 (the original scanning IP), NOT 23.22.63.114 (the brute-force IP)	See Detection 3 in Section 9	Detection
10	Post-compromise web shell upload identified	Obfuscated PHP web shell uploaded via Joomla com_installer (Extension Installer), landed in C:\inetpub\wwwroot\joomla\tmp	POST boc (install_ paramete com_insta stream:ht

4. Investigative Methodology (SPL Queries Used)

Identifying the scanning IP:

```
index=botsv1 imreallynotbatman.com  
| stats count by src_ip
```

Identifying the scanning tool:

```
index=botsv1 sourcetype="stream:http" src_ip="40.80.148.42"
```

→ Inspected `src_headers` field for tool fingerprint.

Identifying the CMS:

```
index=botsv1 sourcetype="stream:http" imreallynotbatman.com
```

→ Inspected `uri_path` field for CMS-specific directory patterns.

Identifying the defacement file:

```
index=botsv1 sourcetype="stream:http" imreallynotbatman.com "GET"  
*.jpg
```

→ Reviewed `uri/uri_path` top values for thematic/anomalous filenames.

Resolving the victim server's internal IP:

```
index=botsv1 sourcetype="stream:dns" imreallynotbatman.com
```

Identifying the malicious dynamic DNS domain:

```
index=botsv1 sourcetype=suricata imnotbatman.jpg  
index=botsv1 sourcetype="stream:http" uri="/poisonivy-is-coming-for-  
you-batman.jpeg"
```

→ Inspected `site/Host` field in raw event for the FQDN.

Identifying the brute-force target username:

```
index=botsv1 sourcetype="stream:http" dest_ip="192.168.250.70"  
uri="*administrator*" http_method=POST
```

→ Inspected raw POST body content for `username=` parameter (not an auto-extracted field — required literal string search).

Counting brute-force attempts:

```
index=botsv1 sourcetype="stream:http" dest_ip="192.168.250.70"  
uri="*administrator*index.php*" http_method=POST "username=admin"  
| stats count
```

→ Note: required quoting the search term as a literal string match, since `username` was not a parsed field in this sourcetype.

Identifying the successful login among 413 attempts:

```
index=botsv1 sourcetype="stream:http" dest_ip="192.168.250.70"  
uri="*administrator*index.php*" http_method=POST "username=admin"  
| table _time, status, bytes  
| sort bytes
```

→ All 413 attempts returned HTTP status 303 (Joomla's standard post-login redirect, used for both success and failure), so status code alone could not distinguish the outcome. Sorting by response size (bytes)

surfaced one clear outlier — 1061 bytes vs. a consistent ~854-857 bytes across all other attempts — indicating the successful login response.

Identifying the post-compromise file upload:

```
index=botsv1 sourcetype="stream:http" dest_ip="192.168.250.70"
src_ip="40.80.148.42" http_method=POST
earliest="08/11/2016:03:18:05" latest="08/11/2016:03:35:00"
| table _time, uri
| sort _time
```

→ Identified a POST request to `index.php?option=com_installer&view=install` — Joomla's built-in Extension Installer, a known technique for uploading malicious PHP payloads through the admin panel. Inspecting the raw `form_data` field revealed an obfuscated PHP web shell submitted via the `install_package` parameter, with `install_directory` confirming it was written directly to `C:\inetpub\wwwroot\joomla\tmp` on the IIS server.

5. Indicators of Compromise (IOCs) Identified So Far

Type	Value
IPv4 (attacker/scanner + successful login)	40.80.148.42
IPv4 (brute-force source + attacker hosting infra, resolved from malicious domain)	23.22.63.114
IPv4 (victim server)	192.168.250.70
Domain (malicious, dynamic DNS)	prankglassinebracket.jumpingcrab.com
Port (non-standard, used by attacker infra)	1337
File (defacement image)	imnotbatman.jpg
File (secondary thematic image)	poisonivy-is-coming-for-you-batman.jpeg
Tooling	Acunetix Web Vulnerability Scanner (Free Edition)
Targeted username	admin
Brute-force volume	413 login attempts
Successful login timestamp	2016-08-11 03:18:05.858 UTC (source IP: 40.80.148.42 — the scanning IP, not the brute-force IP)
Post-compromise payload	Obfuscated PHP web shell, delivered via Joomla <code>com_installer</code> , written to <code>C:\inetpub\wwwroot\joomla\tmp</code>

6. MITRE ATT&CK Mapping (Preliminary)

Tactic	Technique	Evidence
Reconnaissance	T1595 - Active Scanning	Acunetix scan traffic from 40.80.148.42
Resource	T1583.001 - Acquire	Dynamic DNS domain

Development	Infrastructure: Domains	prankglassinebracket.jumpingcrab.c
Initial Access / Exploitation	T1190 – Exploit Public-Facing Application	Joomla CMS targeted
Credential Access	T1110.001 – Brute Force: Password Guessing	413 login attempts against admin account via /administrator/index.pl
Initial Access	T1078 – Valid Accounts	Successful login at 2016-08-11 03:18:05.858 UTC from 40.80.148.42, identified via anomalous response size
Defense Evasion	T1090 – Proxy / Infrastructure Segmentation (attacker TTP, non-standard mapping)	Attacker split noisy brute-force traffic (23.22.63.114) from the quiet successful login (40.80.148.42), like to reduce risk of IP-based blocking
Persistence / Execution	T1505.003 – Server Software Component: Web Shell	Obfuscated PHP web shell uploader via Joomla com_installer, written to C:\inetpub\wwwroot\joomla\tmp
Defense Evasion	T1027 – Obfuscated Files or Information	Web shell used variable renaming, string fragmentation, and gzuncompress/base64_decode/eval() chains to evade signature detection
Defacement / Impact	T1491 – Defacement	Upload of imnotbatman.jpg

(To be refined further as more of the attack chain — including the brute-force and ransomware phases — is investigated.)

7. Lessons / Observations

- The attacker’s own scanning tool inadvertently fingerprinted itself via HTTP headers (Acunetix-Product), demonstrating the value of full-header logging for attribution.
- The defaced content and its supporting image files were thematically branded by the attacker (Batman/Joker-related naming), which aided investigative pivoting once the pattern was recognized.
- Dynamic DNS services (like jumpingcrab.com) are commonly abused by attackers to rapidly change hosting IPs while keeping a stable, memorable domain — an important detection consideration for network defenders (alerting on connections to known dynamic DNS providers can be a useful heuristic).
- Several investigative dead ends occurred before locating the correct FQDN — searching the literal threat actor group name (“po1s0n1vy”) returned zero results, reinforcing that real investigations rely on observable technical artifacts, not narrative labels.
- Building generalized detections (rather than one-off searches tied to a single known IOC) repeatedly surfaced corrections to the initial manual investigation — twice revealing that the attacker had split activity across multiple source IPs (one for scanning, a separate one for brute-forcing, with the successful login circling

back to the original scanning IP). This is a reminder that early assumptions in an investigation should be treated as hypotheses to be stress-tested, not conclusions.

- **CMS landscape note (as of 2026):** This dataset targets Joomla, which has declined sharply in real-world usage since 2016 (from ~9% market share to under 2% today), while WordPress now dominates the CMS market (~59-60% of known-CMS websites). The specific exploited component (`com_installer`) is a legacy Joomla-specific concern; a modern equivalent attack would more likely target WordPress plugin vulnerabilities or hosted/SaaS platform APIs. However, the detection techniques built in this project — volumetric scan detection, brute-force detection, and statistical anomaly detection on HTTP response size — are platform-agnostic and would transfer to a WordPress-based attack with only URI pattern changes (e.g., `/wp-login.php` instead of `/administrator/index.php`).
-

8. Detection Engineering — Saved Alerts

Detection 1: Possible Web Scanning Activity — High Volume Single Source

Purpose: Detect automated vulnerability scanning / reconnaissance based on abnormal request volume from a single source IP within a short time window.

SPL:

```
index=botsv1 sourcetype="stream:http"
| bucket _time span=5m
| stats count by _time, src_ip, dest_ip
| where count > 100
```

Validation: Confirmed true positive — successfully flagged 40.80.148.42 → 192.168.250.70 (the known Acunetix scan) with counts consistently exceeding 700-2500 requests per 5-minute window.

Bonus findings from validation run: - 23.22.63.114 → 192.168.250.70 also flagged (1,235 requests in one window) — a third source IP originally seen in Q1's traffic breakdown (5.8% of total site traffic) that had not yet been individually investigated. **Flagged for follow-up.** - 192.168.2.50 flagged hitting **multiple different destination IPs** (.40, .41, .20, .70) in rapid succession on a different date (Aug 24) — a pattern consistent with **internal network/host scanning** rather than external web scanning. This is a distinct lead, possibly related to a separate compromise or the Scenario 2 (ransomware) storyline. **Flagged for follow-up.**

Splunk alert configuration: - Trigger: Number of Results > 0 (filtering logic handled in SPL via `where count > 100`) - Schedule: Scheduled (lab default: weekly — would be set to every 5 minutes in production) - Actions: Log Event, Email (placeholder)

Detection 2: Brute-Force Login Attempts

Purpose: Detect repeated failed login attempts against a web application admin panel within a short time window.

SPL:

```
index=botsv1 sourcetype="stream:http"
uri="*administrator*index.php*" http_method=POST "username="
```

```
| bucket _time span=10m
| stats count by _time, src_ip
| where count > 20
```

Validation: Confirmed true positive — flagged 23.22.63.114 with 412 login attempts in a single 10-minute window (2016-08-11 03:10:00).

Important correction to earlier findings: This detection revealed that the brute-force attack originated from **23.22.63.114**, a *different* source IP than the one used for initial reconnaissance/scanning (40.80.148.42). The original investigation (Section 3, rows 7-8) had implicitly assumed a single attacker IP throughout; this detection disproved that assumption. Po1s0n1vy operated the attack across at least two distinct source IPs — one for scanning, one for brute-force/exploitation — which itself is a notable TTP (operational security practice to reduce single-IP attribution/blocking risk).

Splunk alert configuration: - Trigger: Number of Results > 0 - Schedule: Scheduled (lab default; production would run every 5-10 minutes) - Actions: Log Event, Email (placeholder)

Detection 3: Anomalous Login Response (Statistical Outlier Detection)

Purpose: Automatically identify a successful login hidden among many failed attempts, by flagging any response size that is a statistical outlier (>2 standard deviations from the mean) — generalizing the manual technique used in Section 4/Q9.

SPL:

```
index=botsv1 sourcetype="stream:http"
uri="*administrator*index.php*" http_method=POST "username="
| eventstats avg(bytes) as avg_bytes, stdev(bytes) as stdev_bytes
| eval is_anomaly=if(bytes > (avg_bytes + 2*stdev_bytes), "YES",
"no")
| where is_anomaly="YES"
| table _time, src_ip, bytes, avg_bytes, is_anomaly
```

Validation: Confirmed true positive — correctly and uniquely flagged the single successful login event: 2016-08-11 03:18:05.858, **src_ip=40.80.148.42**, bytes=1061 (average across all attempts: 854.68).

Important correction to earlier findings: Initial testing of this detection assumed the successful login would come from 23.22.63.114 (the confirmed brute-force IP from Detection 2) and returned no results when filtered to that IP. Removing the IP filter and re-running across all source IPs revealed the successful login actually originated from **40.80.148.42** — the *original scanning IP* — not the brute-force IP.

This reveals a deliberate attacker operational pattern: po1s0n1vy used **23.22.63.114 as a disposable/noisy IP to absorb the 412 failed brute-force attempts** (which would be the most likely traffic to trigger rate-limiting or IP blocking), while reserving their primary IP (40.80.148.42) — already used for earlier “legitimate-looking” reconnaissance — to perform the single, quiet, successful login once valid credentials were obtained. This is a notable piece of attacker tradecraft worth flagging in the MITRE mapping and any downstream detection tuning (e.g., correlating logins from IPs previously seen only in scanning/recon activity).

Splunk alert configuration: - Trigger: Number of Results > 0 - Schedule: Scheduled (lab default; production would run every 5-10 minutes) - Actions: Log Event, Email (placeholder)

Detection 4: Connection to Known Malicious Dynamic DNS Domain

Purpose: IOC-based detection — alert on any traffic to/from confirmed malicious attacker infrastructure (prankglassinebracket.jumpingcrab.com), complementing the behavioral detections above with a direct known-bad indicator match.

SPL:

```
index=botsv1 sourcetype="stream:http" (site="*jumpingcrab.com*" OR uri_domain="*jumpingcrab.com*" OR dest="*jumpingcrab.com*") | table _time, src_ip, dest_ip, uri, site
```

Validation: Confirmed true positive — 2 events matched, both showing the victim server (192.168.250.70) requesting /poisonivy-is-coming-for-you-batman.jpeg from prankglassinebracket.jumpingcrab.com:1337.

Additional clarifying finding: This detection revealed that dest_ip=23.22.63.114 for these requests — meaning the dynamic DNS domain resolved to the **same IP address used for the brute-force attack** (Detection 2). This confirms 23.22.63.114 was po1s0n1vy's actual hosting/attack infrastructure IP (the domain's resolved target), distinct from 40.80.148.42, which was used for reconnaissance and the final quiet successful login. The full attacker infrastructure picture is now:

IP / Domain	Role
40.80.148.42	Reconnaissance scanning (Acunetix) + final successful login
23.22.63.114	Brute-force attempts + resolved target of the malicious domain (hosting infrastructure)
prankglassinebracket.jumpingcrab.com:1337	Dynamic DNS domain pointing to 23.22.63.114, used to serve defacement/thematic image payloads

Splunk alert configuration: - Trigger: Number of Results > 0 - Schedule: Scheduled (lab default; production would run every 5-10 minutes) - Actions: Log Event, Email (placeholder)

9. Summary Dashboard

A single-page Splunk Dashboard Studio dashboard was built consolidating all 4 detections into one operational view:

Dashboard name: Wayne Corp - Website Defacement Investigation Dashboard

Layout: - Summary header (Markdown panel) — plain-language overview of the full attack chain, target, date, and attacker infrastructure - Panel 1: Web Scanning Activity Detected (table) - Panel 2: Brute-Force Login Attempts Detected (table) - Panel 3: Anomalous Login Response - Possible Successful Compromise (table) - Panel 4: Connection to Known Malicious Dynamic DNS Domain (table)

All panels are backed by the same validated SPL used in the corresponding saved alerts (Section 8), so this dashboard reflects live, re-runnable detection logic rather than a static snapshot.

10. New Leads Identified (Pending Investigation)

Lead	Description	Source	Status
23.22.63.114	Third source IP hitting imreallynotbatman.com, never individually investigated — flagged by Detection 1 with high-volume traffic	Detection 1 validation	Resolved — confirmed via Detection 2 as the brute-force source IP (distinct from the scanning IP)
192.168.2.50	Internal host scanning multiple internal destination IPs on Aug 24 — different date/pattern than the defacement incident, may relate to lateral movement or the ransomware scenario	Detection 1 validation	Open

Report generated as part of a self-guided Detection Engineering Lab project using the Splunk BOTS v1 dataset.